TryHackMe — Content Discovery

1. Objective

The objective was to understand **content discovery** and learn how to identify hidden website resources during web application reconnaissance. I successfully completed the TryHackMe room with **100% completion**.

---

2. Concept / Understanding

Content discovery identifies website resources that are not immediately visible through normal browsing. The room covered **Manual Discovery, OSINT, and Automated Discovery** to help map a web application's attack surface.

---

3. Practical Work

1. Opened the TryHackMe Content Discovery room.
2. Completed Task 1: Introduction.
3. Studied common website files used in manual discovery.
4. Completed Task 2: Manual Discovery – Common Files.
5. Reviewed HTTP headers and their security relevance.
6. Studied website framework and technology identification.
7. Completed Task 3: Manual Discovery – Headers & Framework Stack.
8. Learned about Google search operators.
9. Reviewed Wappalyzer and its uses.
10. Completed Task 4: OSINT – Search Engines & Web Tools.
11. Studied the Wayback Machine for historical website information.
12. Reviewed GitHub repositories and S3 bucket exposure risks.
13. Completed Task 5: OSINT – Repositories & Archives.
14. Studied Gobuster directory and file enumeration.
15. Completed Task 6: Automated Discovery – Gobuster Fundamentals.
16. Learned about DNS subdomain enumeration.
17. Studied virtual-host discovery.
18. Completed Task 7: Automated Discovery – Subdomains & Virtual Hosts.
19. Reviewed the three content discovery approaches.
20. Completed Task 8: Conclusion and verified **100% room completion**.

---

4. Tools Used

Tool / Technique	Purpose
Web Browser	Inspect website content and resources.
curl	Review HTTP responses and headers.
Google Search Operators	Find publicly indexed information.
Wappalyzer	Identify website technologies.
Wayback Machine	Review historical website content.
GitHub	Research publicly available repositories.
Gobuster	Discover directories, files, subdomains, and virtual hosts.

---

5. Evidence

----------Screenshot 1----------

How to Access:

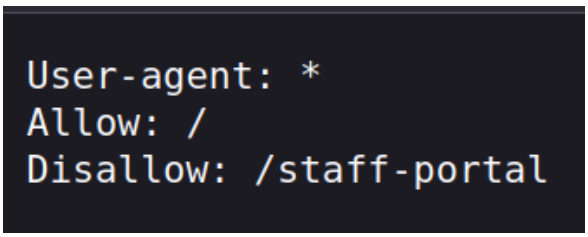
Go to:
http://10.49.140.203/robots.txt

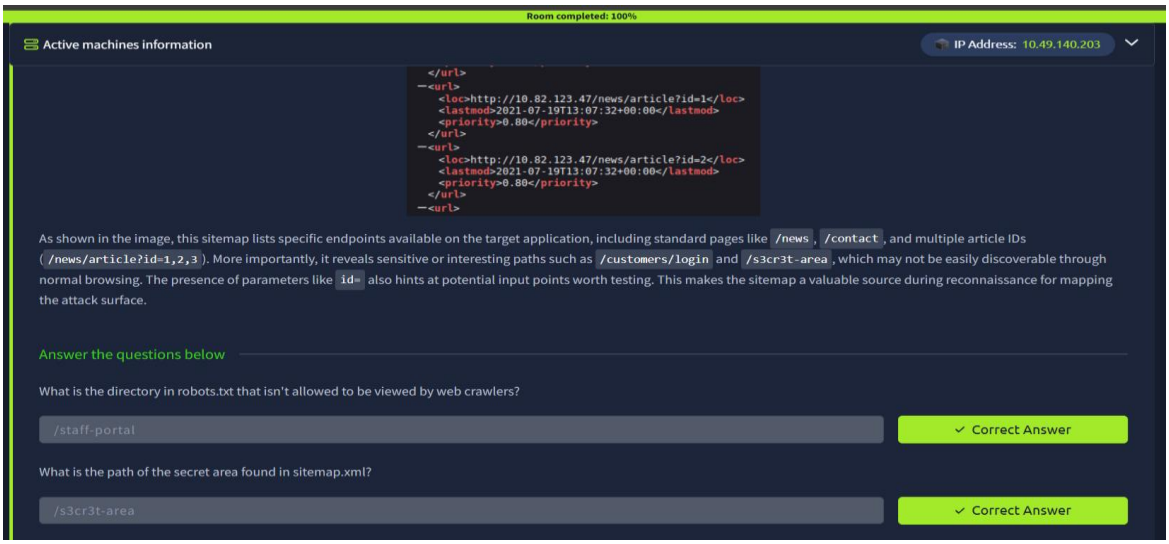
What We Found:

User-agent: *
Disallow: /staff-portal

Answer:

What is the directory in the robots.txt that isn't allowed to be viewed by web crawlers?
Ans: /staff-portal





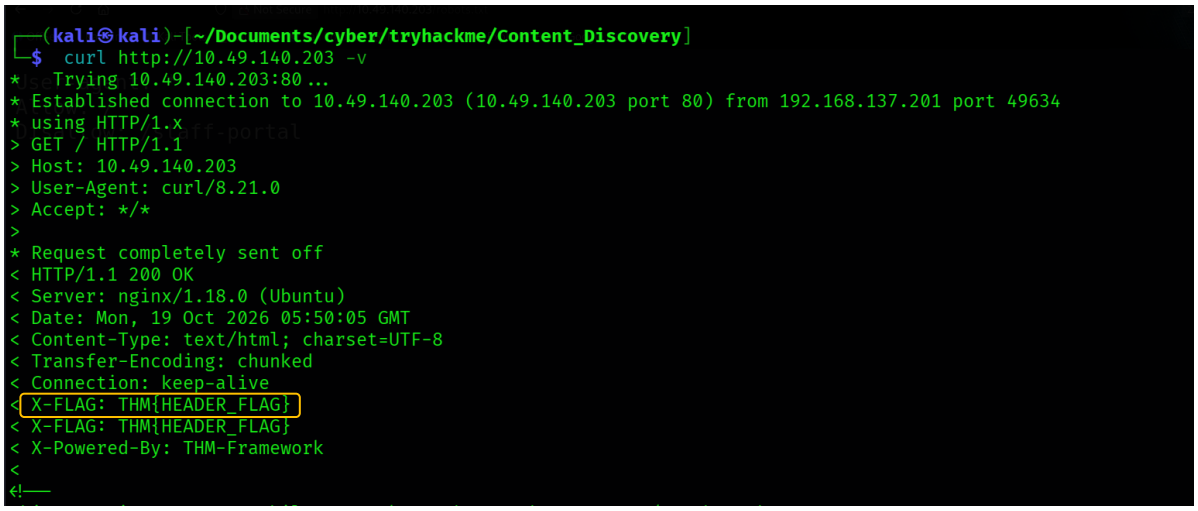
----------Screenshot 2----------

What We Did:

- Ran the following command to inspect HTTP headers:
- curl http://10.10.138.92 -v
- Looked through the response headers for anything interesting

Answer:

What is the flag value from the X-FLAG header?
Ans: THM{HEADER_FLAG}



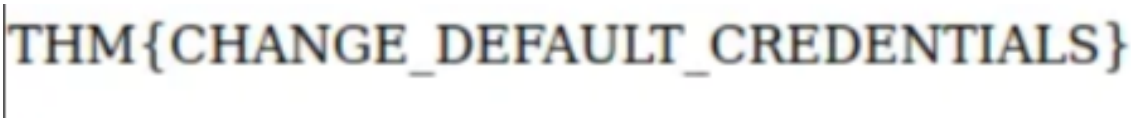
What We Did:

- Viewed the source code of:
  http://10.10.25.208

- Found a comment linking to the framework site: https://static-labs.tryhackme.cloud/sites/thm-web-framework
- Checked the documentation and located the default admin path
- Visited that path on the target site to retrieve the flag

Answer:

What is the flag from the framework's administration portal?
Ans: THM{CHANGE_DEFAULT_CREDENTIALS}





----------Screenshot 3----------

Useful Operators:

site:site:tryhackme.comShow results only from the specified domain

inurl:inurl:adminSearch URLs containing a specific keyword

filetype:filetype:pdfFind files with a specific extension

intitle:intitle:adminShow pages with specific words in the title

Answer:

What Google dork operator can be used to only show results from a particular site?
Ans: site:

Wappalyzer is a powerful OSINT tool (available both as a browser extension and an online service) that helps identify:

- Frameworks
- CMS (Content Management Systems)
- Analytics tools
- E-commerce platforms
- Server technologies

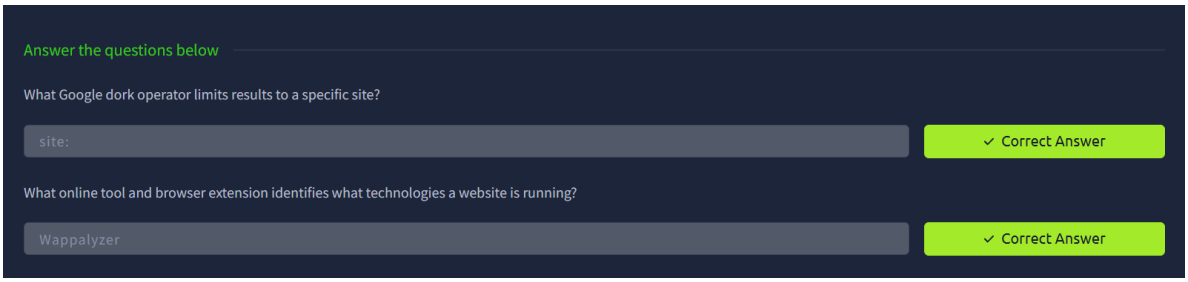
- And even version numbers

What We Did:

- Explored Wappalyzer : https://www.wappalyzer.com/

Answer:

What online tool can be used to identify what technologies a website is running?
Ans: Wappalyzer



----------Screenshot 4----------

What We Did:

- Accessed the Wayback Machine: https://archive.org/web/

Answer:

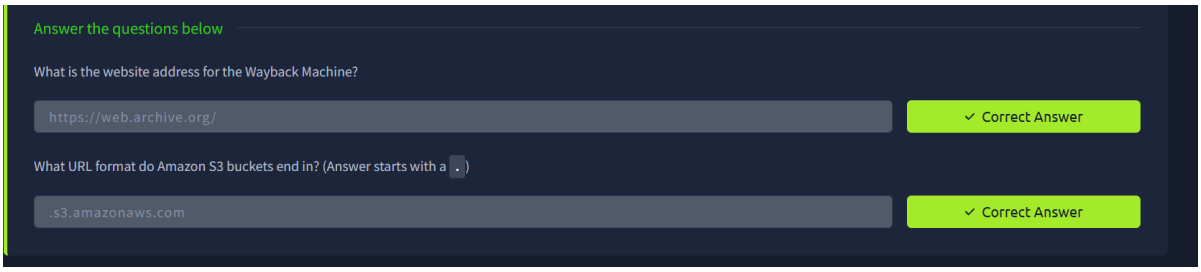
What is the website address for the Wayback Machine?
Ans: https://web.archive.org/

- Amazon **S3 Buckets** are storage solutions by AWS, allowing files to be stored and accessed over HTTP/HTTPS. Misconfigured access permissions may inadvertently expose sensitive content to the public.

S3 Buckets are typically accessible through the URL format:
http(s)://{name}.s3.amazonaws.com

Answer:

What URL format do Amazon S3 buckets end in?
Ans: s3.amazonaws.com



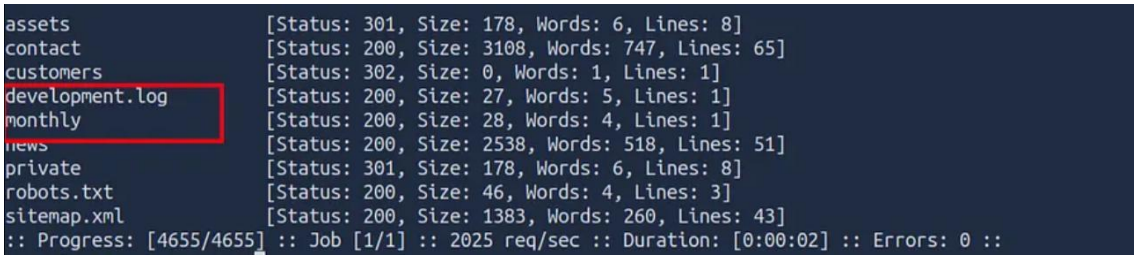
----------Screenshot 5----------

Commands Executed:

- **Using ffuf**:
  ffuf -w /usr/share/wordlists/SecLists/Discovery/Web-Content/common.txt -u http://IP/FUZZ
- **Using dirb**:
  dirb http://IP/ /usr/share/wordlists/SecLists/Discovery/Web-Content/common.txt
- **Using Gobuster**:
  gobuster dir --url http://IP/ -w /usr/share/wordlists/SecLists/Discovery/Web-Content/common.tx

Answers:

- **What is the name of the directory beginning "/mo…." that was discovered?**
  Ans: /monthly
- **What is the name of the log file that was discovered?**
  Ans: development.log





----------Screenshot 6----------



6. Result

Successfully completed the **TryHackMe Content Discovery room (100%)** and gained an understanding of manual discovery, OSINT, and automated enumeration techniques used in web application reconnaissance.

---

7. Key Learnings

- Understood the role of content discovery in web reconnaissance.
- Learned how common website files and HTTP headers reveal useful information.
- Understood how OSINT supports information gathering.
- Learned the fundamentals of Gobuster enumeration.
- Differentiated DNS subdomain discovery from virtual-host discovery.
- Understood why **manual, OSINT, and automated techniques should be combined** for broader coverage.
